DEV-13 · Patch, Update & Maintenance Window Standard

Eight classes of estate in one governing table, remediation timeframes the department can actually hold — and the rule that a vendor patch is an organization change.

Field	Value
Document ID	DEV-13
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	C. Device Usage
Operating tier	Tier 3 — Expert Services owns the update rings, the server and infrastructure regime, and the vulnerability triage. Tier 2 executes endpoint, lab and meeting room patching. Tier 4 approves exceptions and emergency changes and receives the monthly position.
Review cycle	Every six months while the Intune transition is live, then annually.
Relationship to GOV-04	GOV-04 owns change classes, the register, the windows and the freeze calendar. This document owns what is patched, on what cadence, and to what timeframe. Every window named here is a GOV-04 §7 window and every vendor patch is a GOV-04 §8 change. Neither document repeats the other, and where a reader wants the record they should be in GOV-04.

1. Purpose

A familiar case: a vendor engineer applies vulnerability remediation to the test servers of a core business system and then to production, inside the maintenance window, coordinated in an email thread. The sequencing is right, the window is right, and nothing goes wrong. There is simply no organization record that it happened, no organization approver named, and no back-out written down anywhere the organization holds.

Alongside it, Defender for Endpoint sends a vulnerability notification every day. Often nobody is named as the person who triages it, no cadence is defined, and nothing states what closes an item. A daily notification with no triage is not a control — it is a mailbox rule waiting to be written, and it ends the way repeated SLA re-notifications always end: noise, and no action at all.

This document defines the regime: what is patched, by what mechanism, on what cadence, to what timeframe, and who decides when it cannot be. GOV-04 defines the record and the windows. Read together they replace the email thread.

2. What this document commits to, and what it cannot

This section comes before the timeframes deliberately, because the timeframes in §8 will otherwise be read as either impressive or inadequate depending on which framework the reader last saw, and both readings miss the point.

> **A timeframe the department cannot hold is worse than a longer one it can.**
>
> This catalogue is written for small IT teams where most staff wear several hats. The published frameworks a reader might compare this against assume a security function with dedicated staff. A small team does not have one, and a standard written as though it did produces the failure GOV-06 was written to end: targets missed so routinely that everybody stops reading them, and no information about the shortfall reaching anybody who could resource it.
>
> So the timeframes in §8 are stated per GOV-06 capacity state. Under a declared Constrained or Degraded state they extend, by a stated amount, and the extension is declared, recorded and reported. A department that declares Degraded on Monday and reports internal critical remediation at 14 days has told Tier 4 exactly what the staffing shortfall costs, in the department's own operating data (GOV-06 §11). A department that silently misses 7 days has told nobody anything.
>
> One thing never extends, in any state: an actively exploited critical vulnerability on an internet-facing system. If the capacity state means that cannot be met, that is not a deferral — it is a Tier 4 escalation on the day and, where exposure is credible, a GOV-03 matter.
>
> And an extension that nobody declared is a breach, not an extension. The mechanism only works if the state is declared before the target is missed rather than cited afterwards.

3. The estate, by class — the governing table

Eight classes, each with a different regime, in one table. If a system is not in a class below, it is not being patched by anybody, which is itself the finding.

Class	Mechanism	Cadence	Window	Owner
Managed Windows endpoints — staff laptops and desktops	Intune update rings (§4). Windows Update for Business, deadline-driven.	Monthly quality updates; annual feature update, deferred.	None. Installed in the background; restart within the grace period (§12).	Tier 2
macOS endpoints	Intune, provisional pending DEV-09 (§5).	Monthly minor updates; major upgrades deferred and tested.	None; deadline-driven.	Tier 2

Class	Mechanism	Cadence	Window	Owner
Lab and meeting room machines	Intune ring with a maintenance schedule from the booking calendar; image rebuild in a quiet period (§5).	Monthly, outside booked hours. Image in a quiet period.	Overnight. Image rebuild in a quiet-period window.	Tier 2 with the room owner
Conference room, kiosk and presenter devices	As lab and meeting room. No interactive user.	Monthly, overnight.	Overnight; room verified next morning (DEV-18).	Tier 2
Organization-managed servers	Manual or scripted, Test then Production, under a GOV-04 change record (§6).	Monthly. Test one week ahead of Production.	Weekly technical window for Test; secondary or primary window for Production.	Tier 3
Network and infrastructure — switches, firewalls, wireless, UPS firmware	Vendor firmware, under a GOV-04 change record with console access confirmed first (§6).	Quarterly, plus out-of-band for anything critical.	Primary window. Never in a freeze.	Tier 3
Vendor-managed systems — a core business system patched by its vendor, and any other system where a vendor holds maintenance	The vendor applies; the organization approves, holds the back-out and verifies (§7).	The vendor's cadence, approved once as a standing change.	An organization window, from the organization's freeze calendar.	Tier 3 with the system owner; Tier 4 approves
Microsoft 365 and other SaaS	Microsoft patches. The organization tracks and communicates rather than approves.	Continuous. Message centre triaged monthly.	Not applicable.	Tier 3 (M365-21, GOV-04 §8.1)

3.1 What this document does not patch, said plainly

- PERSONALLY-OWNED DEVICES. The organization does not patch them. Patch currency is a condition of access, not something the organization applies (DEV-07). Where it is enforced, it is enforced by DEV-02 conditions rather than by this document.
- DEVICES THAT ARE NOT ENROLLED. An unenrolled device is not a patching gap, it is an enrollment gap, and it belongs to DEV-01. Reporting it here as a patch failure hides the actual problem.
- DEVICES THAT NEVER CHECK IN. The same distinction, and the usual source of escrow gaps: a silent device does not appear as non-compliant, it simply does not appear (DEV-02 §5 step 4). The monthly position in §13 therefore always reports three numbers, never a percentage alone.
- SPECIALIST INSTRUMENT AND LAB CONTROLLERS, where the vendor forbids patching. Those are §11 exceptions with compensating controls, not a ninth class.

4. Managed Windows endpoints: rings, deadlines and the grace period

Four rings. The numbers are stated because a standard that says “promptly” is not a standard, and each is defended below rather than asserted.

Ring	Population	Quality deferral	Feature deferral	Deadline	Grace
Ring 0 — Pilot	IT staff and named volunteers across departments. 15–25 devices, about 2% of the estate.	0 days	30 days	2 days	1 day
Ring 1 — Broad	All other staff endpoints. The great majority of the estate.	3 days	60 days	5 days	2 days
Ring 2 — Shared	Lab, meeting room, conference room, kiosk and presenter devices.	7 days	90 days, or image-based	7 days	Not applicable — patched overnight, no interactive user
Ring 3 — Deferred	A small named set of critical-function devices: an instrument controller, a device running the one application that breaks. Every member is a recorded §11 exception with an expiry.	14 days	180 days	14 days	3 days

4.1 Why these numbers

- WHY A PILOT RING AT ALL. Microsoft’s monthly quality updates occasionally break something, and the organization would rather find out on twenty-five machines than on the whole estate. The pilot must include people who will report a problem rather than work around it silently — which usually means volunteers from outside IT as well as IT staff, because IT staff are unusually good at working around things.
- WHY 3 DAYS AND NOT 7 FOR RING 1. Do the arithmetic. Microsoft publishes on the second Tuesday. A 3-day deferral makes the update available on day 3, the 5-day deadline lands on day 8, and the 2-day grace puts the last unrestarted device at day 10 (§12). A 7-day deferral pushes that to day 14 — which is the outer edge of the HIGH timeframe in §8 for the very vulnerabilities the update fixes, and beyond it for anything critical. The arithmetic is the defence, and it is also why criticals are handled out-of-band under §10 rather than by waiting for a ring.
- WHY A GRACE PERIOD AT ALL. Because a forced restart in the middle of a training session, a board meeting or a payroll run costs the organization more than two days of additional exposure, and because the alternative — users postponing indefinitely — is what produces §12. Two days is long enough to find a convenient moment and short enough that the exposure window stays inside §8.
- WHY A DEADLINE RATHER THAN “AS SOON AS POSSIBLE”. A deadline with no date is a hope, and it is measurable as one. The deadline is the mechanism that makes the compliance figure in §13 mean something.
- WHY RING 2 HAS NO GRACE. There is no interactive user to inconvenience overnight. What Ring 2 has instead is a maintenance schedule taken from the booking calendar and a verification the following morning (§5).

- WHY RING 3 EXISTS AT ALL, AND WHY IT IS NAMED. Because a deferred set will exist whether or not the standard admits it, and an unnamed deferred set has no expiry, no compensating control and no owner. Ring 3 makes the exception visible and countable (§11).

> **These numbers are enforced last, not first**
> Deadlines and forced restarts are turned on by following the DEV-02 §5 sequence — define, measure, report-only, remediate, then enforce — and by device class, smallest and best understood first. Not on a date.
>
> The classic version of this lesson: a rushed phishing-resistant MFA rollout leaves people stuck in an MFA setup loop, because a control was enforced against a population that could not yet satisfy it. A patch deadline enforced across an estate where a material share of devices have not checked in for months produces the same shape of failure, with a restart instead of a login loop.
>
> So before enforcement: confirm the check-in position (DEV-02 §10), confirm the pilot ring reported nothing for two consecutive months, and confirm the notification text in §12 is the specific version rather than the generic one.

---

5. macOS, labs and meeting rooms

5.1 macOS — provisional, and recorded as a gap

- macOS enrollment is under test and DEV-09 is not yet written. Until it is, macOS patch currency is not measurable, and that is stated here rather than left to be inferred from an absent row. It is a recorded gap under GOV-01 §7.
- What is already clear and should be built into DEV-09: minor OS updates enforced with a deferral and a deadline equivalent to Ring 1; major macOS upgrades deferred at least 90 days and tested against the applications the organization actually depends on, because a major macOS release is an application-compatibility event rather than a patch; and the FileVault interaction confirmed before any upgrade is enforced (DEV-03).
- A Mac is included in the §13 monthly position from the moment it is enrolled, even where the only honest entry is “state unknown”. Excluding a class from a report because the standard for it is not finished is how a class stays unmeasured for a year.

5.2 Labs and meeting rooms — patched outside booked hours

- The reason is a priority definition, not a courtesy: a booked session that cannot proceed is a P1 (GOV-06 §4). A restart that interrupts a session converts a routine patch into the highest-priority ticket the department has.
- The maintenance schedule and active hours are configured FROM THE BOOKING CALENDAR, per room, not from a general assumption about when rooms are free. A room used for evening sessions has different quiet hours from a room that empties at four.
- A lab machine that is switched off overnight never patches. This is the practical failure and it is not a policy question — it is a decision, per room, between leaving machines powered, waking them on a schedule, or accepting a slower cadence with the reason recorded. Tier 2 makes it per room and records it (DEV-06).

- Presenter and meeting-room machines are verified before the first session of a busy period and after any image change, because a room that fails does so in front of an audience (DEV-18).
- Anything that cannot be patched in place is carried by the quiet-period image rebuild. The rebuild is a GOV-04 quiet-period window change and is scheduled a quarter ahead, not negotiated in the week before a busy season.
- Conference rooms and kiosks follow the same rule with the same verification. Nobody notices an unpatched kiosk, which is precisely the argument for putting it in the table.

---

6. Servers, network and infrastructure

6.1 The server cycle

1. Read the advisories on publication day and identify anything critical or actively exploited, which leaves this cycle and goes to §10.
2. Raise the change record under GOV-04 §4, with the back-out, before any work begins. Standing monthly patching is approved once as a standard change; each cycle is then a register entry rather than a fresh approval (GOV-04 §3).
3. Confirm a backup or snapshot exists and is verified. “There is a backup” and “the backup restores” are different statements, and the difference is discovered at the worst moment.
4. Apply to TEST, and leave it for a stated interval — seven days for a routine month. Shorter only under §10, and the shortened interval is recorded as a decision rather than as an omission.
5. Apply to PRODUCTION in the window, in a stated order, with the most consequential system last where sequencing permits.
6. Verify against a stated check: services running, an application transaction completed, a report produced. “It booted” is not a verification and neither is “the vendor said it went fine” (GOV-04 §8).
7. Record the ACTUAL start and finish times on the change record. Correlating a change with the tickets it produced is the main day-to-day use of the register and an approximate date defeats it (GOV-04 §4).

6.2 Network and infrastructure firmware

- Quarterly review of firmware currency across switches, firewalls, wireless controllers and UPS units, with the position recorded even where nothing is applied.
- Console or out-of-band access confirmed and tested BEFORE starting, and a back-out image staged. A firewall that does not come back is an organization-wide outage with no remote route to fix it.
- Wireless controller and core switch work takes services down for minutes. Say so in the notice rather than describing it as a maintenance window with no expected impact (GOV-04 §9).
- This is the class most often left because it is working. That is exactly how a five-year-old firmware with a public exploit ends up on the perimeter, and it is why the quarterly review produces a recorded position rather than a look.
- Certificate expiries are not patches, and they belong to the same discipline: diarised, owned, and renewed ahead of the date. The expiry that takes a service down is always the one nobody had in a calendar.

7. Vendor-managed systems — the evidence base, and the rule

> **A vendor patch is an organization change. The rule is GOV-04 §8; what follows is its patching shape.**
> It enters the GOV-04 register, with a named organization approver, a back-out, a test-before-production sequence and a communication — whoever executes it, however routine, and however competent the vendor.
>
> Nothing in the remediation described in §1 is done badly. Test precedes Production, the work sits inside the window, and the engineer is careful. The gap is entirely the record: the organization cannot reconstruct what was applied, could not have told the vendor "not that week" if that week had been a peak week, and has nothing to point at three months later when something on that system behaves oddly.
>
> The vendor's own change process is their internal control. It is not the organization's record, and it is not visible to anybody at the organization.

7.1 What the organization asks for, per cycle

Six lines in an email, which then become the change record. This is the whole administrative cost of the rule and it is worth being explicit that it is small.

- What is being applied, and which advisories, CVEs or vendor bulletins it addresses.
- Which systems, in which order, with Test before Production explicitly stated.
- The expected duration, and the point after which the vendor would abandon and revert.
- The back-out. Where the vendor cannot supply one, that is escalated under GOV-04 §5.2 rather than accepted as normal practice.
- The verification the vendor will perform — and separately, the check the organization will perform itself.
- The requested window, chosen from the organization's published window and freeze calendar.

7.2 What the organization does

1. Approve standing vendor maintenance ONCE, as a standing change with a defined scope, a named window and a stated back-out (GOV-04 §8 step 6). Each execution is then a one-line register entry. This is what stops the process being abandoned for the routine work it was never meant to obstruct.
2. Name an organization approver. The vendor is never the approver of a change to an organization system — not because their judgement is doubted, but because approval is an accountability the organization cannot outsource.
3. Give the vendor the freeze calendar a quarter in advance (GOV-04 §7.1). Peak business weeks are not negotiable, and the usual reason an organization cannot say so is that nobody told the vendor what the freezes were.
4. Have an organization engineer reachable during the window — not necessarily executing, but able to verify afterwards and to escalate if the window overruns.
5. Verify against the organization's own check and record it (§6.1 step 6).

6. Confirm the access the vendor used was a named vendor account, time-boxed rather than standing, and logged (ACC-11 §6, ACC-11 §7). A patch applied through a shared credential is unattributable afterwards.
7. Put the requirement into the contract at renewal (ACC-11 §10). Until it is there, this section depends on goodwill — which is worth having, and is not a control.

- Where a vendor patch is emergency or out-of-band, §10 applies to the vendor exactly as it applies to the organization. Approval may be verbal; the record is deferred, not waived.
- Where a vendor declines to work inside the organization's process, that is a Tier 4 and contract conversation, recorded as such. It is not resolved by the engineer on the day.

---

8. Remediation timeframes by severity

The organization's commitment. The clock starts when the vulnerability is identified TO THE ORGANIZATION — the Defender notification, the vendor advisory, the managed security provider's case — not when somebody gets to it. Recording that start is §9.

Severity	Basis	Normal	Constrained	Degraded
CRITICAL	CVSS 9.0–10.0. Also, at any score: actively exploited in the wild, on the CISA Known Exploited Vulnerabilities list, or exploited in the organization's own estate.	Internet-facing: 48 hours. Internal: 7 coverage days.	Internet-facing: 48 hours. Internal: 10 coverage days.	Internet-facing: 48 hours. Internal: 14 coverage days.
HIGH	CVSS 7.0–8.9.	14 coverage days.	21 coverage days.	30 coverage days.
MEDIUM	CVSS 4.0–6.9.	60 coverage days — the next monthly cycle plus one.	90 coverage days.	The first cycle after the state clears.
LOW	CVSS 0.1–3.9.	With the next scheduled cycle. No separate commitment.	As Normal.	Deferred, and counted.

- THE INTERNET-FACING FIGURE NEVER EXTENDS. It is 48 hours in every capacity state. That is deliverable because the internet-facing population of a small organization is small and known; it would be a fiction across the whole estate.
- An asset holding the sensitive classes in M365-15 takes the tighter of the two applicable figures.
- An ACTIVELY EXPLOITED vulnerability is Critical whatever its CVSS score. A 6.5 with a working exploit in circulation is a more urgent problem than a 9.8 that nobody has weaponised, and a standard that sorts purely by score gets this backwards.
- Where no patch exists, the timeframe applies to the MITIGATION, not to the fix. A mitigation is re-dated, not closed (§9).

- Where the asset is vendor-managed, the timeframe applies to the organization RAISING it with the vendor and to obtaining a date, and the date obtained is recorded against the item. The organization is accountable for pursuing it, not for applying it.

> **Why these figures, and not the ones in the frameworks**
>
> A published framework will suggest something like 15 days for critical remediation across an estate, and a reader who knows those numbers will find the internal figures here relaxed. They are relaxed, deliberately, and this is the honest reasoning.
>
> The 48-hour internet-facing figure is tight because the population is small enough to hold it. The internal figures are longer because they are held by the same people who run the service desk, the migrations, the network and the identity estate, and because a 48-hour internal figure would be missed in the first month, then the second, and by the third nobody would read this document.
>
> What makes this defensible is that the shortfall is visible rather than hidden. The monthly position (§13) reports remediation against these figures alongside the days spent in each capacity state, so the cost of the staffing position is quantified in the department's own numbers rather than argued about. If Tier 4 wants the framework figures, this table is the price list.

---

9. The vulnerability input side — triage, or it is not a control

Most organizations are not short of detection. Defender for Endpoint reports daily, a managed security provider raises cases and holds a weekly review (DEV-14 §8), and vendors publish advisories on a schedule. What is missing is the person, the cadence and the definition of done.

9.1 Inputs

- Defender for Endpoint and Defender Vulnerability Management — daily, and the largest volume by a wide margin.
- Vendor advisories: Microsoft on the second Tuesday, plus your business-system vendors and the network and infrastructure vendors on their own cycles.
- MDR provider cases and the weekly MDR review (DEV-14 §5, DEV-14 §8).
- CISA Known Exploited Vulnerabilities, and any sector or consortium advisory the organization subscribes to.
- A report from a member of staff, a user, or a researcher. Rare, and treated seriously when it happens.

9.2 Who triages, and on what cadence

- A NAMED Tier 3 role, with a named backup. Not "IT", and not "whoever sees it" — an input assigned to everybody is triaged by nobody.
- DAILY: a ten-minute scan for anything Critical or actively exploited, and nothing else. Ten minutes is chosen because it is survivable by a person who also does four other jobs; an hour a day would be abandoned inside a month and the organization would be back to an untriaged inbox.
- WEEKLY: the full triage. New items classified, owners assigned, target dates set from §8, and closed items confirmed as actually closed. Appendix B is the decision table.
- MONTHLY: the position to Tier 4 (§13).

- The daily scan may be skipped under a declared Degraded state; the weekly triage may not. If both are being skipped, that is the capacity signal and it belongs in the monthly report rather than in somebody's conscience.

9.3 What closes an item — exactly four outcomes

Outcome	What it requires
Remediated	The platform confirms the fix is applied — not the technician's recollection of applying it. Recorded with the date and the evidence.
Mitigated	A compensating control is in place: a configuration change, a disabled feature, network isolation. A mitigation is NOT a closure. It carries an expiry and is re-dated at the weekly triage until the fix lands.
Accepted as an exception	A §11 exception with an owner, a compensating control, an expiry and a Tier 4 approver. Not a quiet deferral.
Not applicable	False positive, decommissioned asset, or software that has been REMOVED — which is frequently the fastest close available and is almost never considered (DEV-11 §11).

An item that is none of those four is open, however old and however tedious. It cannot be closed by ageing out of the console view: recommendation lists shorten by themselves as software changes, and a shortening list is not evidence of remediation.

- The triage log holds: what, which assets, severity, date identified, owner, target date per §8, outcome, and date closed. It is small, it is the audit evidence, and it is the source of the numbers in §13.
- Volume is expected to be high and mostly routine. The point of the log is not to record heroism; it is that a critical item cannot get lost in a hundred medium ones.

---

10. Emergency and out-of-band patching

- TRIGGERS: an actively exploited critical vulnerability; a vendor emergency release; or an MDR or Defender case indicating exploitation inside the organization's estate (DEV-14 §5).
- ROUTE: a GOV-04 §10 emergency change. Approved verbally by Tier 4 or the Head of IT, executed, and recorded within one coverage day. The record is deferred, never waived.
- Test-before-production compresses but does not vanish. Even under emergency, apply to one non-production or low-consequence system first and watch it for a stated period where the platform allows. Where it genuinely cannot be done, record that decision and who took it.
- A FREEZE DOES NOT BLOCK AN EMERGENCY PATCH. Freezes cover normal changes; GOV-04 §7.1 already states what proceeds during one, and an actively exploited critical is in that set. Nobody should be arguing about this at 22:00 on a Sunday in peak week.
- The service desk is told before the site, always (GOV-04 §9). An unannounced overnight forced restart across the estate produces a morning of tickets and a loss of trust that costs more than the announcement would have.
- COUNT THEM. A rising number of emergency patches is a finding about the routine cycle — the deferrals are too long, the rings are wrong, or a class of asset is being missed — rather than a run of bad luck (GOV-04 §10).

11. Exceptions, and their expiry

An exception is a device or system that cannot take a patch or an update for a stated technical reason. It uses the same shape as DEV-02 §7 and DEV-12 §5, deliberately, so that nobody has to learn three formats.

- It carries: the asset, the specific patch or version being deferred, the reason, the compensating control, the expiry, the Tier 4 approver, and a review date.
- EXPIRY IS MANDATORY. An exception with no end date is an unpatched system with paperwork.
- The compensating control has to be real: a restricted VLAN or network isolation, no interactive browsing or mail on the device, additional monitoring, or a reduced data scope. “We are careful with it” is not a control.
- There is no exception for convenience, for seniority, or because a restart is inconvenient this week. Those are grace-period conversations (§12).
- END-OF-SUPPORT SYSTEMS ARE NOT EXCEPTIONS. A system past vendor support cannot be patched at all, so there is nothing to defer. It is a risk accepted by Tier 4 with a stated end date and a replacement plan, reported annually to executive leadership, and named as such. This is the class that quietly becomes permanent, and naming it honestly is the only thing that stops it.
- Count exceptions and report the count with its age profile (§13). A rising count means the regime is wrong or the estate is ageing. Both are findings; neither is a reason to stop counting.

12. Reboots, and the people who never restart

> **A patch installed and not restarted is not applied.**
>
> The estate contains machines with uptime measured in months. This is not carelessness. It is unsaved work, twenty open browser tabs, a laptop that takes eight minutes to come back, a deadline on Friday, and a reasonable fear of losing something.
>
> Which is why the mechanism is a deadline with a grace period and then a forced restart — and why the forced restart has to actually fire. A deadline that never enforces is decoration, and everybody works out within two months that it is decoration.

- The notification is SPECIFIC AND DATED, per DEV-02 §6. “Your laptop must restart to finish installing security updates. Please restart by Thursday at 5pm; after that it will restart automatically” is actionable. “Updates are available” is not, and it produces a ticket rather than a restart.
- Within grace, the person may defer. Beyond grace, they may not. Both halves matter: without the first the mechanism is resented, without the second it does not work.
- Active hours are configured so a forced restart does not land during booked sessions on shared devices, and so a laptop does not restart at 10am on a Tuesday because that is when the policy fired.
- RESTART PENDING IS A REPORTABLE STATE. Devices past grace with a restart still pending are listed and contacted individually by Tier 2, and the count appears in §13. Chasing individuals is unglamorous and it is the step that actually closes the gap.
- Presenter machines are restarted and checked before the first session, not during it (DEV-18).

- The honest concession: across any sizeable estate the organization should expect to lose a small amount of somebody's unsaved work to a forced restart each year. It should say so, point at AutoSave, and not pretend otherwise — because the first time it happens to somebody who was told it could not, the mechanism loses its credibility and the department spends a year arguing about it instead of patching.

13. Reporting compliance to Tier 4

Monthly, with the GOV-06 pack. Nine lines, and the last one is the one executive leadership should read.

- ENDPOINT PATCH COMPLIANCE, as three numbers per ring: within deadline, past deadline, and never checked in. Never a single percentage — the third number is the one that would otherwise hide (DEV-02 §10).
- OPEN VULNERABILITIES BY SEVERITY, with age against the §8 timeframe and the count currently breaching it.
- DAYS SPENT IN EACH CAPACITY STATE, and the extensions declared as a result — so the §8 caveat is quantified rather than asserted (GOV-06 §7).
- SERVER AND INFRASTRUCTURE CYCLES: completed, deferred, and why. A deferral with a reason is management information; a deferral with none is a gap.
- VENDOR CYCLES applied, with the GOV-04 register reference for each. This line is the direct answer to the vendor case in §1.
- EMERGENCY PATCHES: count and trend (§10).
- ACTIVE EXCEPTIONS with age, and END-OF-SUPPORT SYSTEMS with their replacement dates (§11).
- DEVICES WITH A RESTART PENDING BEYOND GRACE (§12).
- THE ONE NUMBER: the percentage of CRITICAL vulnerabilities remediated inside the §8 timeframe, broken out by capacity state. It says how the department is performing and what the staffing position costs, in the same figure.

14. Service levels

Activity	Commitment (per GOV-06)
Monthly endpoint cycle	On the Appendix A calendar. Shifted only by a freeze (GOV-04 §7.1).
Critical, internet-facing	48 hours. Does not extend in any capacity state (§8).
Critical, internal / High / Medium / Low	Per the §8 table for the declared capacity state.
Daily critical scan	Ten minutes, within coverage. May be skipped under a declared Degraded state.
Weekly vulnerability triage	On schedule. Not skipped under any capacity state.
Emergency patch — Tier 4 approval	Within 1 coverage hour of the recommendation; verbal is sufficient (GOV-04 §10).
A patch that breaks something	P1 at Tier 3. That is one policy fault, not many device faults.
Exception request	P4 to Tier 4 — 5 coverage days.

Activity	Commitment (per GOV-06)
Vendor window request	Acknowledged within 2 coverage days and scheduled against the published freeze calendar.
Restart chasing beyond grace	Tier 2, within the same monthly cycle.
Monthly position to Tier 4	With the GOV-06 monthly pack.
Quarterly infrastructure firmware review	On schedule, with a recorded position even where nothing is applied.

15. Records

Record	Held in	Retention
Update ring configuration, as approved	Intune, and §4 of this document	Life of the standard
Triage log: item, assets, severity, identified, owner, target, outcome, closed	IT register	3 years
Monthly compliance position	GOV-06 monthly pack	3 years
Change records for server, infrastructure and vendor patching	GOV-04 register	Per GOV-04
Emergency patch records, with the deferred write-up	GOV-04 register	Per GOV-04
Organization verification evidence for each vendor cycle	Change record	3 years
Exceptions: asset, patch, reason, control, expiry, approver	Tier 4 register	Life of the exception + 3 years
End-of-support systems: accepted risk, end date, replacement plan	IT governance record	7 years
Per-room power and maintenance-schedule decisions for labs	Tier 2 record	Life of the room configuration

16. Related documents

ID	Title	Relationship
GOV-04	IT Change Management & Maintenance Windows	The register, the windows and the freeze calendar. §8 there is the rule §7 here applies.
GOV-06	Service Commitments, Priority & Escalation	§7 capacity states — the mechanism that makes the §8 timeframes honest.
GOV-03	Security Incident Response & Escalation Matrix	Where an actively exploited vulnerability with credible exposure goes.

ID	Title	Relationship
DEV-02	Device Compliance & Configuration Baseline	Conditions 4 and 5 are this document. §5 there is the enforcement sequence §4 follows.
DEV-14	Endpoint Security Agent & MDR Escalation Standard	Defender is both the vulnerability input here and the protection agent there. Coverage there determines whether the §9 input is complete.
DEV-01	Device Enrollment & Lifecycle	A device that never checks in is an enrollment problem, not a patch problem (§3.1).
DEV-11	Software Request, Approval, Licensing & Deployment	Who updates a deployed package, and the fastest close in Appendix B — remove it.
DEV-06 / DEV-18	Labs & shared devices / Meeting room AV	§5.2, and the quiet-period image rebuild.
DEV-09	macOS Device Management Standard	§5.1 — the gap this document records rather than fills.
DEV-03	Disk Encryption & BitLocker Recovery Keys	Confirmed before any major OS upgrade is enforced.
DEV-16	Lost, Stolen or Compromised Device Response	A device that has not reported for months may not be unpatched — it may be gone.
ACC-11	Vendor, Contractor & Consultant Account Standard	§6 and §7 — the access a vendor uses inside the window, and the contract clause in §7.2 step 7.
ACC-08	Service, Application & Non-Human Account Standard	Credentials used by patching automation.
M365-21	Tenant Configuration Change Control	The Microsoft 365 row of §3.
M365-15	Data Classification & Handling	The sensitive classes that tighten a §8 timeframe.
GOV-01	SOP Catalog Governance & Document Control	§7 — the macOS gap in §5.1 is recorded there.

Appendix A — The monthly patch cycle calendar

Anchored to Microsoft's second-Tuesday publication, which is day 0. The calendar shifts for freeze weeks and the freeze calendar governs (GOV-04 §7.1).

When	What happens	Who
Day 0 — second Tuesday	Advisories read. Anything critical or actively exploited is pulled out of the cycle and goes to §10 the same day. Nothing else is decided today.	Tier 3
Day 0 – Day 3	Ring 0 pilot installs. Deadline day 2, grace to day 3.	Tier 2
Day 3	Confirm nothing was reported from the pilot, then release Ring 1. A silent pilot is confirmed as silent rather than assumed.	Tier 3

When	What happens	Who
Day 3 – Day 10	Ring 1 broad installs. Deadline day 8, grace to day 10.	Tier 2
Day 7	Ring 2 released to labs, meeting rooms, kiosks and presenter devices; installs in the overnight schedule. Deadline day 14. Rooms verified the following morning.	Tier 2
Day 7 — weekly technical window, Tuesday 06:00–08:00	Server patches applied to TEST. Backup verified first.	Tier 3
Day 14	Ring 3 deferred set released. Deadline day 21. Every member is a live §11 exception and is re-checked here.	Tier 2
Every Wednesday	Weekly vulnerability triage (§9.2). Every open item gets an owner and a date or one of the four outcomes.	Tier 3
Every coverage day	Ten-minute scan for critical and actively exploited items only.	Tier 3
Secondary window — last Sunday, 06:00–10:00	Server patches applied to PRODUCTION, after a full week on Test. Larger work goes to the next primary window instead.	Tier 3
Month end	Monthly position produced for Tier 4 (§13), with the GOV-06 pack.	Tier 3 to Tier 4
Quarterly	Network and infrastructure firmware review, with a recorded position. Applied in the primary window where due.	Tier 3
Quiet period	Lab and meeting room image rebuild, scheduled a quarter ahead (DEV-06, GOV-04 §7).	Tier 2
Vendor cadence	Core business system and other vendor-managed cycles, per the standing change and the organization window (§7).	Tier 3 with the system owner

Appendix B — The vulnerability triage decision table

Worked top to bottom at the weekly triage. The first row that applies decides the item.

	Ask	Then
1	Is it actively exploited, on the CISA KEV list, or exploited in our own estate?	Treat as CRITICAL whatever the CVSS score. Out-of-band under §10, today. Tier 3 now, and Tier 4 informed.
2	Is the affected asset internet-facing or externally reachable?	48 hours for critical, and it does not extend in any capacity state (§8). High takes the tighter figure.
3	Does the asset hold the sensitive classes in M365-15?	Take the tighter figure. Where exposure is credible rather than theoretical, GOV-03 before patching — preserve before you fix (GOV-03 §6).
4	Is the fix something the organization controls?	Yes: assign a named owner and a target date from §8. No: §7 — raise it with the vendor, record the date raised and the date they give, and track it as open.

	Ask	Then
5	Is there a patch at all?	No patch: mitigate — a configuration change, a disabled feature, isolation — and re-date. A mitigation is not a closure and it carries an expiry (§9.3).
6	Is the affected software still needed?	Removing it closes the item permanently and is frequently faster than patching it. Ask before assuming (DEV-11 §11).
7	Will the patch break something known?	A §11 exception: compensating control, expiry, Tier 4 approver. Ring 3 (§4) is where the device goes. Not a silent deferral.
8	Is the system past vendor support?	Not an exception — there is nothing to defer. A Tier 4 accepted risk with an end date and a replacement plan (§11).
9	Does it affect a vendor-managed system?	§7. It enters the GOV-04 register as a vendor change with an organization approver, whoever applies it.
10	Has it actually been remediated?	Verify in the platform, not from memory. Close with the evidence and the date.
11	None of the above?	It stays open. Ageing out of the console view is not closure (§9.3).

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.